

Task 1: What is VAPT?

VAPT (Vulnerability Assessment and Penetration Testing) is a cybersecurity process used to identify security weaknesses in a system, application, network, or server and determine how those weaknesses could be exploited by an attacker.

VAPT combines two activities: Vulnerability Assessment, which focuses on finding and identifying security weaknesses, and Penetration Testing, which involves safely attempting to exploit identified weaknesses to determine their actual impact.

Vulnerability Assessment	Penetration Testing
Mainly identifies and reports security vulnerabilities.	Attempts to exploit vulnerabilities in an authorized and controlled manner.
Usually uses automated scanning tools to find a large number of possible weaknesses.	Uses manual techniques and tools to verify whether vulnerabilities can actually be exploited.

Task 2: Common Vulnerabilities in a Food Delivery App

1. SQL Injection

- SQL Injection occurs when an application does not properly validate user input before using it in database queries. An attacker may manipulate input fields to interfere with database queries.
- Risk: It could potentially allow unauthorized access to or modification of sensitive information such as user or order data.

2. Broken Authentication and Session Management

- This vulnerability occurs when login, password-reset, session, or authentication mechanisms are not implemented securely. For example, poorly protected session tokens could potentially allow an attacker to access another user's account.

- Risk: An attacker could gain unauthorized access to customer accounts, orders, addresses, or other personal information.

3. Insecure Direct Object Reference (IDOR)

- IDOR occurs when an application uses predictable identifiers, such as order IDs or user IDs, without properly checking whether the logged-in user is authorized to access the requested object.
- Risk: An attacker may be able to access another customer's order or account information by changing an identifier in a request.

Task 3: Sample VAPT Report Template

VAPT Security Assessment Report

Application: Fictional E-Wallet Application

Application Name: SecurePay

Assessment Type: Vulnerability Assessment and Penetration Testing

Report Date: _____

Prepared By: _____

Version: 1.0

1. Executive Summary

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) assessment conducted against the fictional SecurePay e-wallet application.

The purpose of the assessment was to identify security weaknesses that could affect the confidentiality, integrity, and availability of application and user information.

Overall Risk Rating

Overall Risk: _____

Key Findings

Critical vulnerabilities: _____

High-risk vulnerabilities: _____

Medium-risk vulnerabilities: _____

Low-risk vulnerabilities: _____

The identified vulnerabilities should be addressed according to their severity and potential business impact.

2. Methodology

The assessment followed a structured security testing process.

Phase 1: Information Gathering

Information about the application's functionality, technologies, endpoints, and attack surface was collected.

Phase 2: Vulnerability Assessment

Automated and manual security testing techniques were used to identify potential vulnerabilities.

Phase 3: Validation

Identified vulnerabilities were reviewed and, where authorized, safely validated to determine their potential impact.

Phase 4: Risk Assessment

Each finding was assigned a risk rating based on factors such as likelihood, potential impact, and ease of exploitation.

Phase 5: Reporting

The vulnerabilities and recommended remediation measures were documented in this report.

3. Vulnerabilities Found

ID	Vulnerability	Severity	Status
VAPT-001	_____	Critical/High/Medium/Low	Open
VAPT-002	_____	Critical/High/Medium/Low	Open
VAPT-003	_____	Critical/High/Medium/Low	Open

Vulnerability Details

VAPT-001: _____

Description:

Affected Component:

Risk:

Recommendation:

VAPT-002: _____

Description:

Affected Component:

Risk:

Recommendation:

VAPT-003: _____

Description:

Affected Component:

Risk:

Recommendation:

4. Risk Ratings

The following risk-rating system is used:

Rating	Description
Critical	Vulnerability could result in severe compromise of the application or sensitive information. Immediate remediation is required.
High	Vulnerability could have significant security or business impact and should be fixed quickly.
Medium	Vulnerability presents a moderate security risk and should be addressed as part of normal remediation activities.
Low	Vulnerability has limited impact but should still be addressed where practical.

5. Recommendations

The following general recommendations should be considered:

1. Apply security patches and update outdated software and libraries.
2. Use secure authentication and session-management mechanisms.
3. Encrypt sensitive information during transmission and storage.
4. Validate and sanitize user input.
5. Implement proper authorization checks for every sensitive resource.

6. Store passwords using strong, modern password-hashing algorithms rather than plain text.
7. Perform regular vulnerability assessments and penetration tests.
8. Monitor application logs and security events for suspicious activity.

6. Conclusion

The VAPT assessment helps identify weaknesses that could potentially be exploited by attackers. The identified findings should be prioritized according to their risk level and remediated within an appropriate timeframe.

After remediation, a follow-up security assessment should be performed to verify that the vulnerabilities have been properly fixed.

Task 4: VAPT Report Entry – Plain-Text Password Storage

Finding ID

VAPT-001

Vulnerability

Plain-Text Storage of User Passwords

Severity

Critical

Description

During the VAPT assessment of the movie ticket booking application, it was discovered that user passwords are stored in plain text in the application's database. This means that anyone who gains unauthorized access to the

database could directly read users' passwords without needing to decrypt or crack them.

Risk

This vulnerability presents a critical security risk because compromised passwords could be used to access user accounts. Users who reuse the same password on other services could also have their other accounts compromised.

Recommendation

Passwords should never be stored in plain text. The application should use a strong, modern password-hashing algorithm such as Argon2id, bcrypt, or scrypt, with a unique salt for each password. Existing plain-text passwords should be securely migrated by requiring users to reset their passwords. Database access should also be restricted using least-privilege principles and protected with appropriate authentication and monitoring.

Status

Open – Remediation Required